

L&B Global CRM Security Review

Prepared for developer handoff | Production security review | May 11, 2026

Executive Summary

This review focused on practical production security for the L&B Global CRM: authentication, authorization, student document handling, public forms, exports, deployment configuration, and common web security controls.

The application has a solid baseline: role-based access checks are present across dashboard routes, Prisma is used for database access, sensitive environment files are ignored by git, and private Vercel Blob support is implemented for student documents. The main remaining work is hardening: dependency upgrades, security headers, rate limiting, tighter record-level authorization, and export/document protections.

Priority Findings

1. Upgrade Vulnerable Dependencies - Critical

npm audit --omit=dev reported high severity advisories affecting Next.js and related dependencies. The Next.js advisories include Server Actions CSRF bypass and multiple denial-of-service issues. Current dependency observed: next@16.1.6. Audit suggested moving to a patched release such as next@16.2.6.

Recommendation: upgrade Next.js and Prisma-related packages, run npm audit again, then run typecheck, build, and smoke tests before deployment.

2. Add Production Security Headers - High

next.config.ts currently configures image domains only. The CRM should add security headers for all routes.

- ? Strict-Transport-Security
- ? Content-Security-Policy including frame-ancestors
- ? X-Content-Type-Options: nosniff
- ? Referrer-Policy
- ? Permissions-Policy
- ? X-Frame-Options if not using frame-ancestors

Affected file: src/next.config.ts or root next.config.ts depending on project structure. In this repo, next.config.ts is at the project root.

3. Add Rate Limiting - High

No rate limiting was visible on login, password reset, the public application form, or chat APIs. These are common abuse targets for credential stuffing, spam, and database/email queue exhaustion.

- ? Login: limit by IP and email.
- ? Forgot password: limit by IP and email.

? Apply form: limit by IP and optionally by email/phone.

? Chat message APIs: limit by user/session.

Recommended implementation: Vercel KV or Upstash Redis with small helper middleware/server-action guards.

4. Cron Route Should Fail Closed - High

The reminder cron route checks the Authorization header only if CRON_SECRET exists. If CRON_SECRET is missing in production, the route becomes callable by anyone.

Affected file: `src/app/api/cron/reminders/route.ts`. Recommendation: if CRON_SECRET is missing, return 500 or 401 and do not process the job.

5. Tighten Record-Level Access for Contracts and Invoices - High

Contract and invoice preview pages allow any ADMIN, SUB_ADMIN, or INTERNAL_STAFF to access records by ID. For CRM data, role-level access is not enough. Internal staff should only access assigned students. Sub-admins should follow their assigned/unassigned queue rules.

Affected files: `src/app/dashboard/contracts/[contractId]/preview/page.tsx` and `src/app/dashboard/invoices/[invoiceId]/preview/page.tsx`.

Recommendation: add a shared `canAccessStudentProfile(user, studentProfileId)` helper and use it before viewing, editing, sending, marking paid, or deleting records.

6. Protect CSV Exports Against Formula Injection - Medium

CSV values are quoted, but spreadsheet apps can still execute cells beginning with `=`, `+`, `-`, or `@`. Student-provided values such as name, city, course, notes, or source fields can become formulas when opened in Excel or Google Sheets.

Affected files include `src/app/api/submissions/export/route.ts`, `src/app/api/sub-admin/report/route.ts`, and `src/app/api/internal-staff/report/route.ts`.

Recommendation: update `csvCell` to prefix risky values with an apostrophe before escaping.

7. Keep Student Documents Out of Public Storage - Medium

Production should use private Vercel Blob for student documents. The fallback storage path writes to `public/student-docs` for local development. Those files are ignored by git, which is good, but production should fail closed if Blob is not configured.

Affected file: `src/lib/storage.ts`. Recommendation: keep `BLOB_READ_WRITE_TOKEN` and `BLOB_STORE_ACCESS=private` in Vercel, and avoid public fallback outside local development.

Recommended CRM Security Features

? Require MFA for ADMIN, SUB_ADMIN, and INTERNAL_STAFF accounts.

? Use a stronger staff password policy: 12+ characters and common-password blocking.

- ? Log sensitive actions: document access/download, contract/invoice send/delete, password resets, staff changes.
- ? Add account lockout or progressive delay after repeated login failures.
- ? Review all staff permissions quarterly.
- ? Preserve Google Workspace SPF, DKIM, and DMARC records after DNS migration.
- ? Use private Blob storage for documents and authenticated app routes for file access.
- ? Back up the database and test restore procedures.
- ? Create a staff offboarding checklist to disable accounts immediately.

Suggested Fix Order

1. Upgrade Next.js and vulnerable dependencies.
2. Add security headers in next.config.ts.
3. Make the cron endpoint fail closed when CRON_SECRET is missing.
4. Add rate limiting to login, reset password, apply form, and chat endpoints.
5. Add shared record-level authorization for student-linked contracts and invoices.
6. Harden CSV exports against formula injection.
7. Enforce MFA and stronger password policy for staff.
8. Confirm SPF, DKIM, and DMARC records are present for lbglobal.com.au.

Validation Checklist for Developers

- ? npm audit --omit=dev returns no high severity production issues or has documented exceptions.
- ? npm run typecheck passes.
- ? npm run build passes.
- ? Unauthenticated users cannot access dashboard, API, document, report, invoice, or contract routes.
- ? Internal staff cannot access records for unassigned students.
- ? CSV exports open safely in Excel/Sheets without formula execution.
- ? Student document URLs require authentication when Blob store is private.
- ? Cron route rejects missing or incorrect Authorization header.
- ? Security headers are visible in production response headers.

Overall Assessment

The CRM is close to a reasonable production baseline, but it should not be treated as fully hardened until the dependency, rate limiting, headers, cron, and record-level authorization issues are addressed. The strongest immediate wins are upgrading Next.js, adding headers, and closing the authorization gaps around student-linked financial/contract records.